

Vetting third-party vendors

General standards for GDPR compliance

	Yes	No
1. Does the vendor have a GDPR-compliant privacy policy?		
a. Does it include a commitment to:		
■ Data principles?		
■ Data protection by design?		
■ Processing data lawfully?		
■ The rights of data subjects?		
b. Does it include:		
■ The vendors approach to information security?		
■ Certifications in place if the vendor stores and processes financial data?		
■ Requirements for staff training?		
2. Does the vendor have GDPR-compliant privacy notice?		
a. Does it include:		
■ A description of the information the vendor collects?		
■ Why the data is collected?		
■ How it is processed?		

■ Who any data is shared with?		
■ The details of any processors and sub-processors?		
■ How long data is kept for?		
3. Is the vendor registered with the ICO?		
4. Does the vendor use data for marketing to customers?		
a. Do customers have the opportunity to select communication preferences or opt-out (legitimate interests are cited)?		

Controller-Processor contracts

	Yes	No
5. Does the vendor have a GDPR-compliant privacy policy?		
a. Does it include a commitment to:		
■ Data principles?		
■ Data protection by design?		
■ Processing data lawfully?		
■ The rights of data subjects?		
6. Is there a contract or data sharing agreement in place between the Controller and the vendor (Processor)?		
7. Does the contract with the vendor include the following:		
■ The subject matter, duration, nature and purpose of the data processing?		
■ The type of personal data being processed?		

■ The categories of data subjects whose personal data is being processed?		
■ The obligations and rights of the Controller?		
8. Does the processor only act on the controller's documented and explicit instructions (unless required by law to act without such instructions)?		
9. Does the contract include terms on data confidentiality?		
10. Are the vendor's information security standards included in the contract?		
11. Does the contract require the use of a sub-processor?		
■ Does the Controller approve and authorise the sub-processors in the contract?		
12. Does the contract include procedures for supporting the Controller with:		
■ data subjects rights?		
■ Data breaches?		
■ Data Privacy Impact Assessments?		
13. Does the contract stipulate all personal data will be deleted or returned at the end of the contract (unless continued storage is required by law)?		
14. Does the processor agree to audits and inspections?		
15. Does the processor agree to provide the controller whatever information it needs to ensure they are both meeting their Article 28 obligations?		